Module-1

Overview of Security Parameters:

Information Security

- What is Information Security(InfoSec)?
- Information security is the practice of protecting information by mitigating information risks.
- It involves the protection of information systems and the information processed, stored, and transmitted by these systems from unauthorized access, use, disclosure, disruption, modification, or destruction.
- This includes the protection of personal information, financial information, and sensitive or confidential information stored in both digital and physical forms.
- Effective information security requires a comprehensive and multi-disciplinary approach, involving people, processes, and technology .
- Information can be anything like Your details or we can say your profile on social media, your data on your mobile phone, your biometrics, etc. Thus Information Security spans so many research areas like Cryptography, Mobile Computing, Cyber Forensics, Online Social Media, etc.

History of Information Security

•**Ancient Cryptography**: Early methods like the Caesar cipher used by Julius Caesar to protect military messages.

•**World Wars**: Significant advancements in cryptography, including the Enigma machine and efforts by cryptanalysts like Alan Turing.

•**1950s-1960s**: Development of mainframes and early concepts of access control and security protocols.

•**1970s**: Introduction of the Data Encryption Standard (DES) and public-key cryptography by Diffie and Hellman.

•**1980s**: Emergence of personal computers, computer viruses, and antivirus software; formation of Computer Emergency Response Team(CERT) in response to the Morris Worm.

•**1990s**: Growth of the internet, development of firewalls, intrusion detection systems, and SSL; introduction of the Computer Fraud and Abuse Act.

•**2000s**: Increased focus on e-commerce security, advanced encryption, multi-factor authentication, and the Payment Card Industry Data Security Standard (PCI DSS).

•**2010s**: High-profile breaches, rise of ransomware, state-sponsored attacks, and advanced persistent threats (APTs); introduction of General Data Protection Regulation (GDPR).

•**2020s**: Continued evolution with AI and machine learning in cybersecurity, challenges from IoT, and the potential impact of quantum computing.

•**Current Focus**: Developing resilient systems, improving threat intelligence, and creating comprehensive security frameworks to protect against diverse threats.

Security Parameters



Security Parameters

Information security is necessary to ensure the confidentiality, integrity, and availability of information, whether it is stored digitally or in other forms such as paper documents. Information Security programs are build around 3 objectives, commonly known as CIA – Confidentiality, Integrity, Availability.

Confidentiality: Ensures that information is accessible only to those authorized to have access. Techniques include encryption and access controls. Means information is not disclosed to unauthorized individuals, entities and process. For example if we say I have a password for my Gmail account but someone saw while I was doing a login into Gmail account. In that case my password has been compromised and Confidentiality has been breached.

Integrity: Guarantees that data is accurate and has not been tampered with. Methods include hashing, checksums, and digital signatures. Means maintaining accuracy and completeness of data. This means data cannot be edited in an unauthorized way. For example if an employee leaves an organization then in that case data for that employee in all departments like accounts, should be updated to reflect status to JOB LEFT so that data is complete and accurate and in addition to this only authorized person should be allowed to edit employee data.

Availability: Ensuring that information and resources are available to authorized users when needed. This involves measures like redundancy, failover systems, and robust backup strategies.

The CIA Triad

What Is the CIA?

Confidentiality	Integrity	Availability
The information is safe from accidental or intentional disclosure.	The information is safe from accidental or intentional modification or alteration.	The information is available to authorized users when needed.
Example		
I send you a message, and no one else knows what that message is.	I send you a message, and you receive exactly what I sent you (without any modification)	I send you a message, and you are able to receive it.
What's The Purpose of the CIA?		
Data is not disclosed	Data is not tampered	Data is available
How Can You Achieve the CIA?		
e.g., Encryption	e.g., Hashing, Digital signatures	e.g., Backups, redundant systems
Opposite of CIA		
Disclosure	Alteration	Destruction

Security Violations

Security violations refer to breaches or infringements of established security policies, procedures, or practices, leading to unauthorized access, use, disclosure, disruption, modification, or destruction of information. These violations can result from both intentional and unintentional actions by insiders or external actors and can significantly impact the confidentiality, integrity, and availability of information.

Types of Security Violations

1.Unauthorized Access:

1. **Definition:** Gaining access to systems, data, or resources without proper authorization.
2. **Examples:** Hacking into a secure system, using stolen credentials.

2.Data Breach:

Definition: Unauthorized acquisition, access, or disclosure of sensitive or confidential information.

Examples: Exfiltration of personal data, leaking confidential company information.

3.Privilege Escalation:

Definition: Exploiting a vulnerability to gain elevated access to resources that are normally protected.

Examples: Using a bug to gain administrator privileges on a system.

4.Insider Threat:

Definition: Security violations committed by trusted individuals within the organization.

Examples: Employees stealing or leaking sensitive information, deliberate data corruption

Security Threats

- In the context of information security, **threats** are potential events or actions that can cause harm to an organization's information systems by exploiting vulnerabilities.
- These threats can come from various sources, including malicious attackers, internal users, natural disasters, and system failures.
- They can lead to unauthorized access, data breaches, service disruptions, and other adverse impacts on the confidentiality, integrity, and availability of information.

1. Malware

- **Description:** Malicious software designed to harm or exploit any programmable device, service, or network.
  Examples: Viruses, worms, trojans, ransomware, spyware, adware.

What is Malware Attack?

- Attackers use many methods to get malware into a user's device, most often social engineering.
- Users may be asked to take an action, such as clicking a link or opening an attachment.
- In other cases, malware uses *vulnerabilities in browsers* or operating systems to install themselves without the *user's knowledge* or *consent*.
- Once malware is installed, it can monitor user activities, send confidential data to the attacker.
- It assist the *attacker in penetrating other targets* within the network, and even cause the user's device to participate in a botnet leveraged by the attacker for malicious intent.

- **Malware attacks include:**
  - ✓ Trojan virus
  - ✓ Ransomware
  - ✓ Wiper malware
  - ✓ Worms
  - ✓ Spyware
  - ✓ Fileless malware
  - ✓ Application or website manipulation

(a)Trojan virus —

Tricks a user into thinking it is a **harmless file**. A Trojan can launch an attack on a system and can establish a ***backdoor***, which attackers can use.

(b) Ransomware —

Prevents access to the data of the victim and threatens to delete or publish it unless a ransom is paid.

(c) Wiper malware —

Intends to ***destroy data or systems***, by ***overwriting targeted files*** or ***destroying an entire file system***. Wipers are usually intended to send a ***political message***, or hide hacker activities after data exfiltration.

(d) Worms —

This **malware** is designed to exploit **backdoors** and **vulnerabilities** to gain **unauthorized access to operating systems**. After installation, the worm can perform **various attacks**, including **Distributed Denial of Service (DDoS).**

(e) Spyware —

This **malware** enables malicious actors to gain **unauthorized access to data**, including sensitive information like **payment details** and **credentials**. **Spyware** can affect **mobile phones**, **desktop applications**, and **desktop browsers**.

2. Phishing

Description: Fraudulent attempts to obtain sensitive information by pretending to be a trustworthy entity in electronic communications. Examples: Phishing emails, spear phishing, whaling (targeting high-profile individuals).

•

Phishing —

- Attackers **send** fraudulent correspondence that seems to come from legitimate sources, usually via ***email***.
- The email may urge the user to perform an important action or click on a link to a malicious website, leading them to hand over sensitive information to the attacker, or expose themselves to malicious downloads.
- Phishing emails may include an **Email attachment infected with malware**.

3. Man-in-the-Middle (MitM) Attacks

- **Description:** An attacker intercepts and potentially alters the communication between two parties without their knowledge.
  Examples: Eavesdropping on unencrypted Wi-Fi, session hijacking, Replay attack
- **Session hijacking** —

  an attacker hijacks a session between a network server and a client. The attacking computer substitutes its IP address for the IP address of the client. The server believes it is corresponding with the client and continues the session.
- **Replay attack** —

  a cybercriminal eavesdrops on network communication and replays messages at a later time, pretending to be the user. Replay attacks have been largely mitigated by adding timestamps to network communications.

- **IP spoofing** —or IP address spoofing refers to the creation of internet protocol packets with a false source IP address to impersonate another computer system.

an attacker convinces a system that it is corresponding with a trusted, known **entity**.

The system thus provides the attacker with access. The attacker ***forges its packet with the IP source address*** of a trusted host, rather than its own IP address.

- **Eavesdropping attack** — or listening attack

attackers and listens to ***communications between two parties without there knowledge or consent ,*** to access information transmitted between the client and server.

These attacks are difficult to detect because network transmissions appear to act normally.

4. Denial-of-Service (DoS) Attacks

Description: A Denial of Service (DoS) attack is a malicious attempt to disrupt the normal functioning of a targeted server, service, or network by overwhelming it with a flood of internet traffic. The goal of a DoS attack is to make the target system unavailable to its intended users by exhausting its resources, such as bandwidth, memory, or processing power**.**

Examples: Flood attacks, application-layer attacks.

Distributed denial of service (DDoS)

- The objective of a **denial of service** (DoS) attack is to overwhelm the resources of a target system and cause it to stop functioning, denying access to its users.
- Distributed **denial of service** (DDoS) is a variant of DoS in which attackers compromise a large number of computers or other devices, and use them in a coordinated attack against the target system.
- DDoS attacks are often used in combination with other ***cyberthreats***.
- These attacks may launch a **denial of service** to capture the attention of security staff and create confusion, while they carry out more subtle attacks aimed at stealing data or causing other damage.

5. Advanced Persistent Threats (APTs)

- **Description:** Prolonged and targeted cyberattacks in which an intruder gains access to a network and remains undetected for an extended period.
  Examples: State-sponsored hacking, corporate espionage.

6. Insider Threats

- **Description:** Threats from individuals within an organization who misuse their access to harm the organization's information systems.
  Examples: Disgruntled employees, accidental data leaks.

7. SQL Injection

- **Description:** A code injection technique that exploits a vulnerability in an application's software by inserting malicious SQL statements into an entry field.
  Examples: Unauthorized viewing of lists, deletion of records

8. Password Attacks

- **Description:** Attempts to obtain or decrypt a user's password to gain unauthorized access to a system.
  Examples: Brute force attacks, dictionary attacks, credential stuffing.
- A hacker can gain access to the password information of an individual by 'sniffing' the connection to the network, using social engineering, guessing, or gaining access to a password database.
- An attacker can 'guess' a password in a random or systematic way.

Password attacks include:

Brute-force password guessing — an attacker uses software to try many different passwords, in hopes of guessing the correct one. The software can use some logic to trying passwords related to the name of the individual, their job, their family, etc.

How to protect yourself against a security breach

- **Use strong passwords:**

  which combine random strings of upper and lower-case letters, numbers, and symbols. They are much more difficult to crack than simpler passwords.

- **Use different passwords on different accounts:**

  If you use the same password, a hacker who gains access to one account will be able to get into all your other accounts.

9.Social Engineering

- **Description:** Psychological manipulation of people into performing actions or divulging confidential information. An attacker pretends to be an IT support technician and convinces an employee to disclose their login credentials for troubleshooting purposes

  Examples: Pretexting, baiting, tailgating, vishing (voice phishing).
- **Baiting:**

Enticing a victim with a promise of a reward to encourage them to take a specific action, often leading to a compromise.

- **Example:** Leaving a USB drive labeled "Confidential Salary Info" in a public place. When someone finds it and plugs it into their computer, malware is installed.

10. Supply Chain Attacks

- **Description:** Attacks that target less secure elements in the supply chain to compromise a final target.

  Examples: Software updates, hardware components, service providers.

Security policy and procedure

What is a security policy?

- A security policy is a document that states in writing how a company plans to protect its physical and information technology (IT) assets. Security policies are living documents that are continuously updated and changing as technologies, vulnerabilities and security requirements change.
- A company's security policy may include an acceptable use policy. These describe how the company plans to educate its employees about protecting the company's assets. They also include an explanation of how security measurements will be carried out and enforced, and a procedure for evaluating the effectiveness of the policy to ensure that necessary corrections are made.

- **Why are security policies important?**
- Security policies are important because they protect an organizations' assets, both **physical** and **digital.** They identify all company assets and all threats to those assets.
- **Physical security policies** are aimed at protecting a company's physical assets, such as buildings and equipment, including computers and other IT equipment. Data security policies protect intellectual property from costly events, like data breaches and data leaks.
- **Physical security policies**
- Physical security policies protect all physical assets in an organization, including buildings, vehicles, inventory and machines. These assets include IT equipment, such as servers, computers and hard drives.
- Protecting IT physical assets is particularly important because the physical devices contain company data. If a physical IT asset is compromised, the information it contains and handles is at risk. In this way, information security policies are dependent on physical security policies to keep company data safe.

- Physical security policies include the following information:
- sensitive buildings, rooms and other areas of an organization;
- who is authorized to access, handle and move physical assets;
- procedures and other rules for accessing, monitoring and handling these assets; and
- responsibilities of individuals for the physical assets they access and handle.
- Security guards, entry gates, and door and window locks are all used to protect physical assets. Other, more high-tech methods are also used to keep physical assets safe. For example, a biometric verification system can limit access to a server room. Anyone accessing the room would use a fingerprint scanner to verify they are authorized to enter.

Information security policies:

- These policies provide the following advantages.
- Protect valuable assets: These policies help ensure the confidentiality, integrity and availability -- known as the *CIA triad* -- of data. They are often used to protect sensitive customer data and personally identifiable information.
- Guard reputations: Data breaches and other information security incidents can negatively affect an organization's reputation.
- Ensure compliance with legal and regulatory requirements: Many legal requirements and regulations are aimed at security sensitive information. For example, Payment Card Industry Data Security Standard dictates how organizations handle consumer payment card information. Health Insurance Portability and Accountability Act details how companies handle protected health information. Violating these regulations can be costly.

- **Dictate the role of employees.**
- Every employee generates information that may pose a security risk. Security policies provide guidance on the conduct required to protect data and intellectual property. Identify **third-party vulnerabilities.**
- Some vulnerabilities stem from interactions with other organizations that may have different security standards. Security policies help identify these potential security gaps.

Remote workers put data and storage at risk



- People are working in less secure environments.
- The lines between workplace and home have blurred.
- Workers are more likely to misuse applications and services.
- Employees at home are more likely to adopt informal work habits.
- People are adjusting to new ways of working.
- Insiders have more opportunities to carry out malicious behavior.

SOURCE: ROBERT SHELDON; ILLUSTRATION: VISUAL GENERATION/ADOBE STOCK

©2020 TECHTARGET. ALL RIGHTS RESERVED TechTarget

New security concerns have emerged as employees moved into remote workspaces in response to the COVID-19 pandemic. Companies must consider these as they update their security policies.

- **Types of security policies**
- Security policy types can be divided into three types based on the scope and purpose of the policy:

1. **Organizational.** These policies are a master blueprint of the entire organization's security program.
2. **System-specific.** A system-specific policy covers security procedures for an information system or network.
3. **Issue-specific.** These policies target certain aspects of the larger organizational policy.

Examples of issue-related security policies include the following

Acceptable use policies define the rules and regulations for employee use of company assets.

1. Access control policies: say which employees can access which resources.
2. Change management policies :provide procedures for changing IT assets so that adverse effects are minimized.
3. Disaster recovery policies: ensure business continuity after a service disruption. These policies typically are enacted after the damage from an incident has occurred.
4. Incident response policies :define procedures for responding to a security breach or incident as it is happening.

- **Key elements in a security policy**

Some of the key elements of an organizational information security policy include the following:

- statement of the purpose;
- statement that defines who the policy applies;
- statement of objectives, which usually encompasses the CIA triad;
- authority and access control policy that delineates who has access to which resources;
- data classification statement that divides data into categories of sensitivity -- the data covered can range from public information to information that could cause harm to the business or an individual if disclosed;

- data use statement that lays out how data at any level should be handled -- this includes specifying the data protection regulations, data backup requirements and network security standards for how data should be communicated, with encryption, for example;
- statement of the responsibilities and duties of employees and who will be responsible for overseeing and enforcing policy;
- security awareness training that instructs employees on security best practices -- this includes education on potential security threats, such as phishing, and computer security best practices for using company devices.
- effectiveness measurements that will be used to assess how well security policies are working and how improvements will be made.

What is security procedure when creating a security policy?

- Security professionals must consider a range of areas when drafting a security policy. They include the following:
- Cloud and mobile: It is important for organizations to consider how they are using the cloud and mobile applications when developing security policies. Data is increasingly distributed through an organization's network over a spectrum of devices. It is important to account for the increased amount of vulnerabilities that a distributed network of devices creates.
- Data classification: Improperly categorizing data can lead to the exposure of valuable assets or resources expended protecting data that doesn't need to be protected.
- Continuous updates: An organization's IT environment and the vulnerabilities it is exposed to change as the organization grows, industries change and cyberthreats evolve. Security policies must evolve to reflect these changes.
- Policy frameworks: The National Institute of Standards and Technology (NIST) offers its Cybersecurity Framework, which provides guidance for creating a security policy. The NIST approach helps businesses detect, prevent and respond to cyber attacks.

Assumption and Trust

- Trust is a belief or desire that a computer entity will do what it should do to protect resources and be safe from attack.
- However, in the realm of computer security, trust has a very specific meaning. We will define trust in terms of a related concept.
- Definition: An entity is trustworthy if there is sufficient credible evidence leading one to believe that the system will meet a set of given requirements.
- Definition: Trust is a measure of trustworthiness, relying on the evidence provided.

- Assumptions in Information Security **Security Models and Protocols**: **Trusted Computing Base (TCB):** Assumes that certain hardware, software, and firmware components are secure. **Cryptographic Protocols**: Assume that the cryptographic algorithms and keys are secure. **User Behavior:** User Compliance: Assumes users will follow security policies and practices. Password Management: Assumes users will create and manage strong passwords.

System and Network Integrity:

•**Patch Management**: Assumes that systems are regularly updated and patched.

•**Network Security**: Assumes that network defenses like firewalls and intrusion detection systems are effective.

Data Handling:

•**Data Encryption**: Assumes encrypted data cannot be easily decrypted without the key.

•**Access Control**: Assumes that access control mechanisms are correctly implemented and enforced.

- Trust in Information Security **Trust Relationships**: Authentication: Trust in the identity of users or systems.
- Authorization: Trust that users have the appropriate permissions.
- **Third-Party Services:** Cloud Providers: Trust in the security practices of cloud service providers.
- Software Vendors: Trust that software and updates provided by vendors are secure and free of malicious code.

•**Certificates and Public Key Infrastructure (PKI)**:

•**Digital Certificates**: Trust in the validity of certificates issued by Certificate Authorities (CAs).

•**SSL/TLS**: Trust that secure communication channels are truly secure.

•**Trust Models**:

•**Zero Trust Model**: Assumes no implicit trust; verifies every request as if it originates from an open network.

•**Web of Trust**: Trust is decentralized and based on endorsements by trusted parties.

- The Interplay between Assumptions and Trust

- Assumptions Underpin Trust: Assumptions about the security and behavior of systems and users underpin the level of trust we place in them. For example, we assume that cryptographic algorithms are robust, which allows us to trust encrypted communications.

- Assumptions are Risks: Assumptions can be sources of vulnerabilities. If an assumption proves false (e.g., a trusted system component is compromised), it can undermine trust and security. Regular Re-Evaluation: Assumptions and trust relationships should be regularly re-evaluated and validated. Security audits, penetration testing, and continuous monitoring help ensure that assumptions hold and trust is justified

- Challenges and Considerations
- Human Factors: Trust in user behavior is often misplaced, leading to vulnerabilities through social engineering, phishing, and poor password practices.
- Technological Evolution: As technology evolves, assumptions about what is secure can become outdated. Continuous assessment and adaptation are necessary.
- Complexity of Trust: Trust relationships can be complex and multifaceted, involving multiple entities and layers of security.

Security Assurance

- Security assurance in information security refers to the measures and processes used to ensure that systems, applications, and data remain secure and protected from unauthorized access, breaches, and other security threats. It involves a combination of practices, methodologies, and technologies designed to safeguard the confidentiality, integrity, and availability of information.
- Here are key components and practices involved in security assurance:

1. **Risk Management**: Identifying, assessing, and mitigating risks to information systems and data. This includes conducting risk assessments, developing risk mitigation strategies, and implementing controls to reduce risk to an acceptable level.
2. **Security Policies and Procedures**: Establishing formal security policies, procedures, and guidelines that govern how information systems and data are to be protected. These policies provide a framework for implementing and managing security controls.

3. Access Control: Implementing mechanisms to control who can access information and what actions they can perform. This includes authentication (verifying the identity of users) and authorization (determining what resources a user can access).

4. Encryption and Data Protection: Using cryptographic techniques to protect data in transit and at rest. This ensures that even if data is intercepted or accessed without authorization, it remains unreadable and secure.

5. Security Audits and Assessments: Regularly conducting security audits and assessments to evaluate the effectiveness of security controls and identify vulnerabilities. This includes, vulnerability assessments and compliance audits.

6. Continuous Monitoring: Implementing continuous monitoring of information systems and networks to detect and respond to security threats in real-time. This includes the use of intrusion detection and prevention systems (IDPS), security information and event management (SIEM) systems, and other monitoring tools.

7. Security Awareness Training: Educating employees and stakeholders about security risks and best practices. This helps to create a security-conscious culture and reduces the likelihood of human errors leading to security breaches.

8. Compliance with Standards and Regulations: Ensuring that security practices comply with relevant industry standards, regulations, and legal requirements. This may include standards like ISO/IEC 27001, NIST Cybersecurity Framework, and regulations like GDPR or HIPAA.

Implementation and Operational Issues

- In order to determine the safety of data from potential violations and cyberattacks, the implementation of the security model has an important phase to be carried out. In order to ensure the integrity of the security model, it can be designed using two methods:
- **1. Bottom-Up Approach:** The company's security model is applied by system administrators or people who are working in network security or as cyber-engineers. The main idea behind this approach is for individuals working in this field of information systems to use their knowledge and experience in cybersecurity to guarantee the design of a highly secure information security model.
- **Advantages:** An individual's technical expertise in their field ensures that every system vulnerability is addressed and that the security model is able to counter any potential threats.
- **Disadvantage:** Due to the lack of cooperation between senior managers and relevant directives, it is often not suitable for the requirements and strategies of the organization.

- **2. Top-Down Approach:** This type of approach is initialized and initiated by the executives of the organization.
- They formulate policies and outline the procedures to be followed.
- Determine the project's priorities and expected results
- Determine liability for every action needed
- **Advantages of Top-Down Implementation:**
- This approach looks at each department's data and explores how it's connected to find vulnerabilities. Managers have the authority to issue company-wide instructions while still allowing each person to play an integral part in keeping data safe. Compared to an individual or department, a management-based approach incorporates more available resources and a clearer overview of the company's assets and concerns.
- A top-down approach generally has more lasting power and efficacy than a bottom-up approach because it makes data protection a company-wide priority instead of placing all the responsibility on one person or team. Data vulnerabilities exist in all offices and departments, and each situation is unique. The only way for an information security program to work is by getting every manager, branch, department, and employee in agreement with a company-wide plan.

Operational Issues in Information Security

- Any security policy or mechanism must find a balance between the benefits of protection and the costs of implementation and use. This balance involves analyzing the risks and likelihood of security breaches, which is often subjective.
- Additionally, the acceptability of security measures is influenced by laws, customs, and societal norms, which can change over time, affecting both security mechanisms and policies.

1.Cost-benefit analysis: In computer security involves comparing the value of protecting data against the cost of implementing security measures. If protecting the data costs more than the data's value, then security measures may not be justified.

- **Example:**
- **Critical Data:** A database with salary information must be strongly protected to prevent financial loss from tampering.
- **Non-Critical Data:** Copies of this database used by branch offices for recommendations don't need strong protection, as they don't make financial decisions.
- Sometimes, the analysis isn't straightforward, like deciding on the need for confidentiality of salary data. The cost of a security measure also depends on how it interacts with other security mechanisms. Implementing security from the start is usually more cost-effective than adding it later.

2.Risk Analysis:

- Risk analysis in information security involves assessing potential threats to assets and the likelihood of those threats occurring to determine the necessary level of protection. This involves evaluating the probability and impact of possible attacks and prioritizing protection based on their likelihood and severity.
- For example:
- a)A car manufacturing plant performs a risk analysis to examine potential hazards in the manufacturing process. This analysis pinpoints risks such as equipment failure and accidents, as well as evaluates their likelihood and potential consequences.
- b)An international shipping project being planned by a transport company involves a risk analysis for potential project hazards, such as shipping costs, product damage and delays. According to the study, the project is feasible, so the business decides to reduce risks by purchasing shipment insurance and increasing its contingency reserve.

3 Laws and Customs

- Laws restrict the availability and use of technology and affect procedural controls. Hence, any policy and any selection of mechanisms must take into account legal considerations.
- **Example**
- Until the year 2000, the United States controlled the export of cryptographic hardware and software (considered munitions under United States law). If a U.S. software company worked with a computer manufacturer in London, the U.S. company could not send cryptographic software to the manufacturer. The U.S. company first would have to obtain a license to export the software from the United States. Any security policy that depended on the London manufacturer using that cryptographic software would need to take this into account.
- **Example**
- Suppose the law makes it illegal to read a user's file without the user's permission. An attacker breaks into the system and begins to download users' files. If the system administrators notice this and observe what the attacker is reading, they will be reading the victim's files without his permission and therefore will be violates the laws and customs , considered legal action can be taken against that.

The Information Security Lifecycle

- Like most sectors of IT, security professionals can follow a lifecycle model throughout their daily work lives. However, most security professionals will indicate that their work is not linear and static.
- While this statement is agreed upon, it is also believed that these lifecycles provide a valuable foundation for any security program or professional to build upon.
- Using a lifecycle model as a security professional provides a guide that ensures continuous progress in the security posture of the enterprise.
- A security program is not a static assessment or something that could ever be considered a “finished product,” free from any possible improvement. Instead, a security program requires constant attention, upkeep, and enhancement.

- **Security Policy and Standards — The Foundation of Information Security Lifecycle**
- Before a clear lifecycle for a company’s security can be established, it is essential to first define the policies and procedures that will form the foundation of the security team's operations.
- These policies and procedures are critical as they serve as the fundamental "Step 0" in the lifecycle, upon which the entire security plan is built.
- Establishing clear policies and standards tailored to the security team's composition is crucial for both the assessment and protection aspects of the security program.
- The assessment side of the program will utilize these established standards and policies as benchmarks for evaluating efforts and resources. Additionally, the protection side of the program will be configured and prioritized based on these preliminary standards.
- Overall, the entire security lifecycle is constructed around the policies and standards prioritized by the security team. Without clear procedures and standards to adhere to, the lifecycle will be disjointed and ineffective in practice. The importance of policies and standards in the program is further illustrated in the accompanying graphic.


Monitor
Identify
Policies
and Standards
Protect
Assess

Identify — Step 1 of the Information Security Lifecycle

- The first step in the information security lifecycle is to identify what needs to be protected. It's impossible to protect assets that are not visible or known. This initial step involves mapping the network, identifying servers, and understanding the applications running on them. The identification process should start at a high level and then progress to a more detailed level. Proper security posture formation requires identifying and understanding available resources and the assets that need protection.

Important questions to ask within the company include:

- How many servers, firewalls, and routers are there?
- What operating systems are running?
- What applications and software are running on the systems?
- What is the reach of these applications, and which departments use them (e.g., HR, Marketing)?
- Where are the physical assets located?
- What are the company’s top-priority assets?

- Answering these questions requires a thorough audit of the company's posture. This should be done through internal interviews and discussions, as well as external tools and platforms. Internal sources include fellow security professionals, IT staff, and employees from other departments. External resources provide an unbiased view to gather all necessary information for a complete picture.
- One popular and useful external tool is NMAP(Network Mapper). NMAP is an open-source tool that is effective for discovering networks and identifying details such as used applications and operating systems. Additionally, NMAP can be run on almost any device, which is crucial for mapping the entire security network.
- After gathering all necessary data, it is important to create a secure document to store the information for later use. This database should include details such as host names, operating systems, business applications used, and network locations. This information will be vital for future steps in the information security lifecycle.

Assess — Step 2 of the Information Security Lifecycle

- The assessment phase of the information security lifecycle builds on the information gained in the previous step. Once all assets have been identified and documented, the next step is to perform a thorough security assessment of these assets.
- This step encompasses all aspects of assessment, from reviewing current processes and procedures to performing vulnerability scans.
- For larger enterprises, it can be overwhelming to decide where to start due to the numerous components within the network that require protection.
- The key is to prioritize based on the most important assets. Begin with servers and assets that are the most vulnerable and critical to the organization. Focusing on the most important and exposed areas ensures that the most significant improvements are made first.
- During the network assessment, it is vital to continue collecting information and then perform the actual assessment.
- This involves learning as much as possible about the applications, their configurations, and the locations of various components. The goal is to drill down from a high level to obtain more granular details. After consultation, a thorough vulnerability assessment should be conducted.

- A widely used vulnerability scanner in the information security field is **Nessus**. (Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network). which integrates with **PlexTrac**,(PlexTrac is a popular software application that ranks 41 among all Risk Management Software according to our research analysts. Starting from $3500)provides extensive information to the security team by discovering the network and identifying and assessing each system for vulnerabilities.
- Nessus is crucial for both the identification and assessment steps of the information security lifecycle. Additional tools like **SuperScan** and **BlackWidow** are also useful in this phase.
- The overall objective of the assessment step is to examine all resources at all levels to identify vulnerabilities and obtain detailed information about each resource within the company.
- This supplements the high-level overview obtained in the identification phase and refines it with more granular details.

Protect — Step 3 of the Information Security Lifecycle

- After assessing the network and obtaining detailed information, it is crucial to protect the network by aligning systems with the previously established policies and standards.
- This step, often referred to as the "mitigation" step, aims to mitigate all risks identified during the assessment phase. The focus of this phase is to configure and strengthen each system and network component.
- The goal is to ensure that systems and networks adhere to the corporate policies established before the lifecycle began. Given the potential multitude of servers, routers, and other components in the network, determining where to start can be challenging.
- A good practice is to begin with small changes to non-critical aspects of enterprise components. Implementing significant changes to critical infrastructure can be risky if done incorrectly and without thorough testing

- Instead, gradual changes help build trust and ensure that implementations do not create new problems.
- Additionally, it is essential to follow established deployment processes, especially when moving from gradual changes to addressing larger, more critical issues. Another crucial aspect of the protection step is **determining the appropriate level of protection** for each resource.
- All resources must meet a certain security threshold, but the security team must decide the appropriate level of protection for each resource. For instance, confidential information vital to business operations should be protected at the highest possible level, whereas less sensitive or largely public information may require lower prioritization and protection.
- The overall goal of this protection phase is to ensure security standards align with earlier established policies and standards and to eliminate vulnerabilities, making the network as secure as possible.

- The final step of the information security lifecycle is to Monitor
- The security measures in place, including recently updated or changed security configurations.
- Once the security posture has been strengthened, it is essential to ensure it remains robust. This step involves monitoring not only the changes made but also any new systems introduced into the company's network ecosystem.
- As computer systems and servers are constantly being changed and updated, a process must be implemented to monitor the security status across the enterprise continuously.
- The frequency of monitoring certain resources depends largely on the value of the resource, as established in the protection step.
- Every system must be periodically checked to ensure no vulnerabilities are exploited, but more valuable resources should be monitored more frequently to safeguard critical assets. Verifying and ensuring security compliance is the primary goal of the monitoring step

- Key questions to address include: Are the systems safe? How is safety ensured? Continuous assessment and monitoring of important assets help provide clear answers to these questions.
- Tools such as Tripwire, Microsoft's Security Configuration and Analysis tool, and various benchmarking tools from the Center for Internet Security (CIS), like PlexTrac, can provide real-time views of the security posture and facilitate collaboration for future remediation efforts.
- The overarching goals of the monitoring step are to continually monitor security and measure performance against the company's standards. Just as in other business areas, measuring security is necessary to ensure progress is made and security resources are properly implemented into the network.

Thank you